

INGENIERÍA SOCIAL

EL ESLABON MÁS DEBIL

Hackeando la mente humana antes que al sistema [Módulo 2: Ataques, conceptos y técnicas]



¿QUÉ ES LA INGENIERÍA SOCIAL?

En ciberseguridad, la ingeniería social es una técnica de manipulación psicológica. Los atacantes la utilizan para engañar a los usuarios con el fin de que cometan errores de seguridad, revelen información confidencial o cedan el acceso a sistemas críticos. Según el curso de Cisco, es mucho más fácil explotar la confianza o el miedo de una persona que encontrar un fallo técnico en el software.



¿POR QUÉ ES RELEVANTE PARA LA ORGANIZACIÓN?

- Anulación de barreras tecnológicas: Las organizaciones invierten miles de dólares en firewalls (cortafuegos) y criptografía, pero todo esto se vuelve inútil si un empleado entrega voluntariamente sus credenciales.
- El factor humano: Los atacantes saben que el personal es el perímetro de seguridad más vulnerable. Apelan a emociones como la urgencia, la autoridad, la codicia o la curiosidad para lograr su objetivo de manera rápida y económica.



TÁCTICAS COMUNES DE INGENIERÍA SOCIAL



Phishing y Spear Phishing: Correos electrónicos fraudulentos que suplantán identidades legítimas (bancos, jefes) para robar datos o instalar malware. El Spear Phishing es altamente personalizado hacia un individuo específico.

Tailgating (Seguimiento de cerca): Un atacante físico sigue muy de cerca a un empleado autorizado para colarse por una puerta de seguridad hacia un área restringida antes de que esta se cierre.

TÉCNICAS DE MANIPULACIÓN

Pretexting (Pretexto): El atacante inventa una situación falsa y convincente (ej. llamar haciéndose pasar por soporte técnico) para ganarse la confianza de la víctima y solicitar contraseñas.

Quid Pro Quo (Algo por algo): Se ofrece un beneficio a cambio de información o acceso, como regalar memorias USB infectadas o prometer un premio falso.



EL ÉXITO DE UN ATAQUE DE INGENIERÍA SOCIAL DESENCADENA COMPROMISOS GRAVES:

1. **Robo de Identidad y Credenciales:** Permite al atacante acceder a la red corporativa como si fuera un usuario legítimo, dificultando su detección.
2. **Infección por Malware/Ransomware:** Al hacer clic en enlaces engañosos, la red entera puede quedar cifrada y secuestrada.
3. **Brechas de Datos (Data Breach):** Fuga de propiedad intelectual o datos de clientes, lo que genera multas millonarias y daño a la reputación corporativa.
4. **Compromiso Físico:** El tailgating permite el robo de equipos físicos (laptops, discos duros) o la conexión de dispositivos maliciosos directamente en los servidores.



¿CÓMO SE MITIGAN ESTOS ATAQUES?



Educación y Concientización

Entrenar continuamente al personal para que identifique correos sospechosos, desconfíe de solicitudes inusuales de información y verifique la identidad del remitente.



Políticas de Seguridad Físicas y Lógicas

Establecer reglas estrictas de "no sostener la puerta a extraños" (mitigar el tailgating) y políticas de verificación de múltiples pasos para transferencias de dinero o cambios de contraseñas.



Controles Tecnológicos (Defensa en Profundidad)

Implementar Autenticación Multifactor (MFA) para que, incluso si el usuario entrega su contraseña, el atacante no pueda acceder. Usar filtros de correo anti-phishing para bloquear mensajes maliciosos antes de que lleguen al empleado.

